

Projeto de Bloco - TP2

E-ComShield | Análise exploratória e segurança da API
Autores: Nathalia Calazans Artigas e Daniel Augusto da Silva
27 de setembro de 2026

Problema e objetivo

Aprofundar a análise de textos de e-commerce com correlação, visualizações e teste de hipótese formal; verificar os controles de segurança da API FastAPI e registrar um scan passivo real do OWASP ZAP. O B2W fornece avaliações reais em português, enquanto o Bitext fornece rótulos de intenção publicados pela fonte.

Fontes e separação metodológica

Fonte	Papel neste TP	Volume após preparo
Bitext Retail eCommerce	EDA das intenções originais; base de treino do baseline	44.884 textos; 46 intenções; 13 categorias
B2W-Reviews01	Feedback real em PT-BR; hipótese de comprimento do texto	132.373 linhas originais; 131.347 após limpeza
Amostra B2W anotada	Validação externa futura, sem contaminar o treino	500 rótulos humanos; 422 elegíveis sem marca de incerteza

Regra importante: a nota do B2W não é rótulo de intenção. O projeto não usa as antigas heurísticas de palavras-chave como ground truth. O Bitext é inglês e híbrido/sintético; a avaliação PT-BR humana permanece separada do treinamento.

Reprodutibilidade

- Downloads fixados por revisão e SHA-256; scripts verificam a integridade antes da EDA.
- Partições do Bitext determinísticas, estratificadas por intenção e sem texto idêntico entre treino e teste.
- Notebooks 03 e 04 contêm a EDA executada; o relatório completo está em [reports/tp2_data_eda/relatorio.md](#).

EDA aprofundada: correlações e relações

O heatmap usa Spearman para atributos numéricos do Bitext: comprimentos de solicitação e resposta, em caracteres e palavras, e presença de interrogação. Intenção e categoria são nominais e não foram convertidas em números arbitrários.

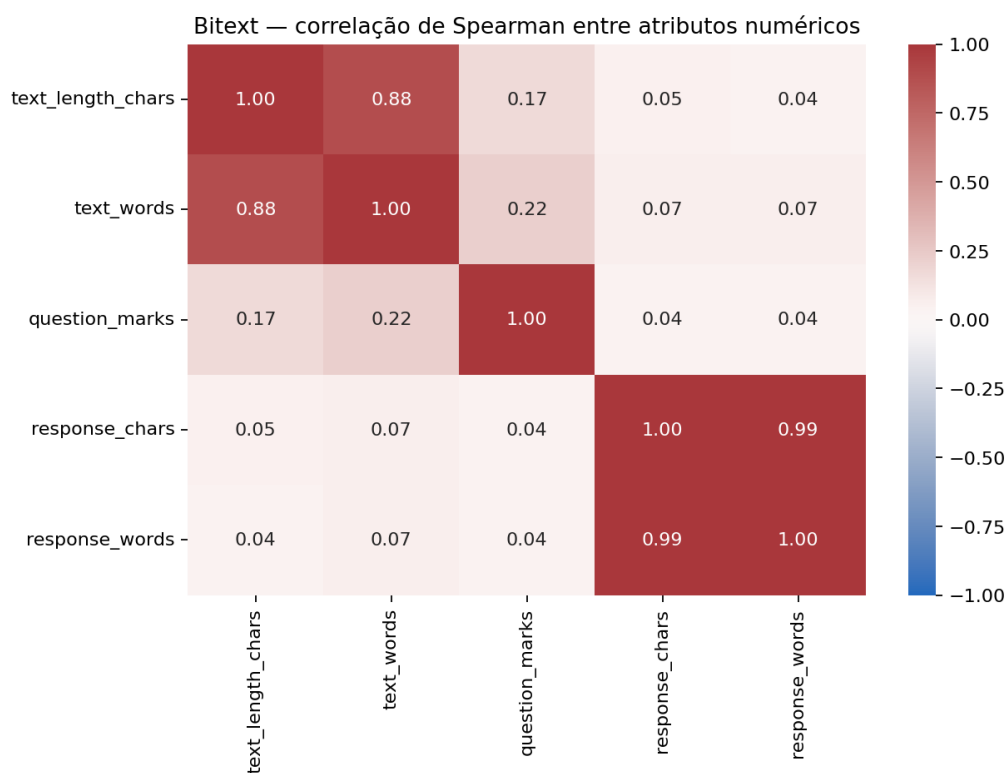


Figura 1. Correlações de Spearman no Bitext.

Caracteres e palavras da solicitação têm correlação aproximada de 0,88; as duas medidas da resposta, 0,99. A correlação entre comprimento de solicitação e resposta é apenas 0,05. As duas primeiras associações são em grande parte mecânicas; nenhuma delas demonstra causalidade ou qualidade do classificador.

EDA aprofundada: dispersões

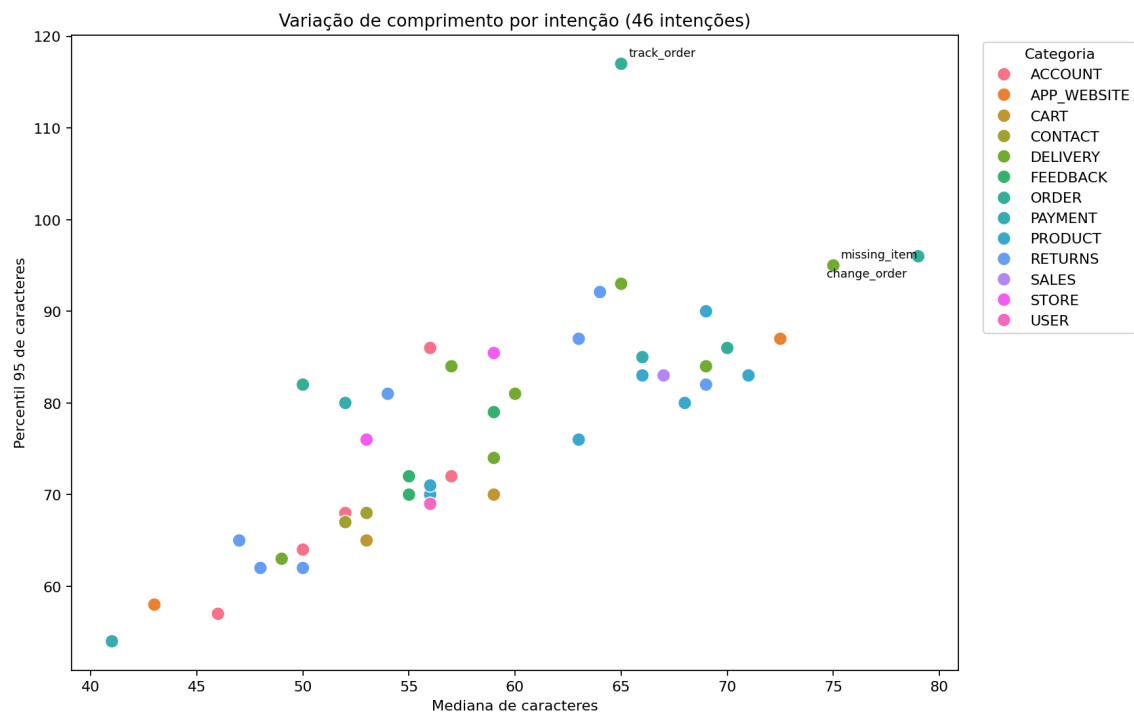


Figura 2. Mediana e percentil 95 do comprimento por intenção.

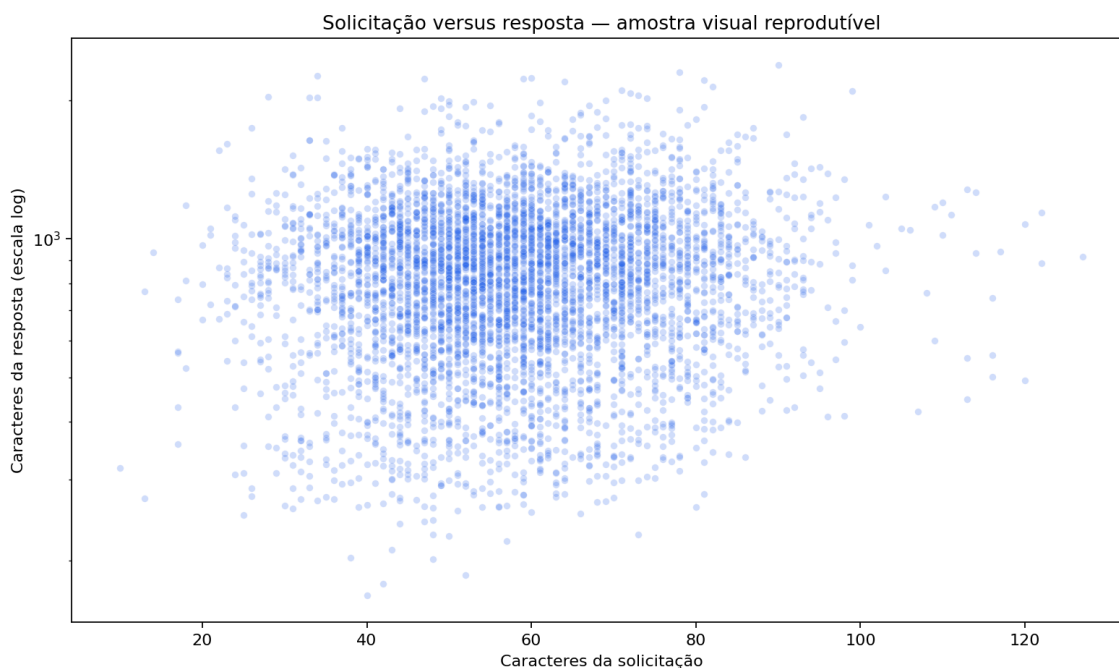


Figura 3. Comprimento da solicitação versus resposta em amostra reprodutível de 5.000 linhas.

O primeiro gráfico cobre as 46 intenções. Em `track_order`, o percentil 95 chega a 117 caracteres, contra 84 no conjunto. O segundo gráfico usa `random_state=42` para legibilidade visual; as estatísticas são calculadas com todas as linhas elegíveis.

Hipótese formal no B2W

Hipótese do TP1: avaliações negativas tendem a ter textos mais longos. Comparamos notas 1-2 com notas 4-5, excluindo nota 3. Aplicamos Mann-Whitney U unilateral (aproximação assintótica, com correção de empates) porque os comprimentos são assimétricos.

Análise	n (notas 1-2 / 4-5)	Medianas	p unilateral	Efeito
Todas as avaliações	35.020 / 80.111	154 / 102 caracteres	$< 10^{-300}$	P(superioridade)=0,6771
Primeira por revisor	31.313 / 69.028	154 / 102 caracteres	$< 10^{-300}$	P(superioridade)=0,6762

No teste principal, $U=1.899.459.581,5$; a diferença descritiva entre medianas é 52 caracteres. A probabilidade de superioridade de 0,6771 significa que, em pares de grupos diferentes, o texto de nota baixa tende a ser mais longo em cerca de 67,7% das comparações, contando empates pela metade. O p-valor não é zero.

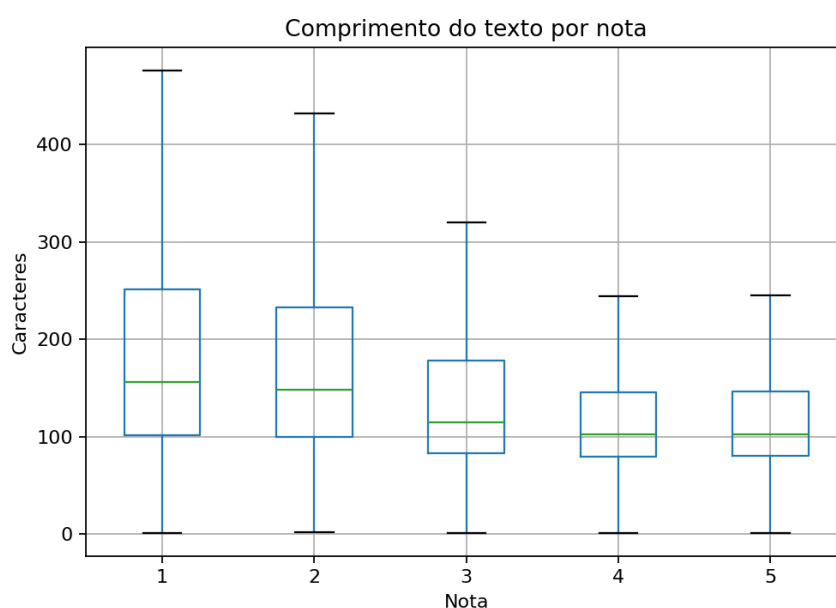


Figura 4. Comprimento dos feedbacks por nota no B2W.

A sensibilidade por primeira avaliação cronológica de cada revisor preserva quase todo o efeito. Este teste é exploratório: a hipótese foi formulada após olhar o TP1, e fatores de produto ou perfil do revisor podem confundir a associação. Mann-Whitney não prova, por si só, uma diferença causal ou de medianas.

API e controles OWASP

Controle	Implementação e evidência
Validação	Modelos de entrada Pydantic com extra='forbid'; campos inesperados retornam 422.
Persistência e BOLA	SQLModel com PostgreSQL; recursos vinculados ao usuário; leitura por ID exige dono ou administrador.
Headers e CORS	HSTS, X-Frame-Options, X-Content-Type-Options e CSP; origens CORS em allowlist explícita.
Brute force	POST /auth/token: 5 tentativas por IP em janela móvel de 60 segundos; resposta 429 com Retry-After.

Justificativa e limite do rate limiting

Cinco tentativas por minuto reduzem rajadas de tentativa de senha e ainda toleram poucos erros de digitação. É uma escolha para demonstração local, não garantia universal: o contador fica na memória, reinicia com o processo, não é compartilhado entre workers e entre usuários atrás do mesmo IP/NAT. Produção exige armazenamento compartilhado, tratamento de proxy/IP e monitoramento.

Verificações executadas

- pytest tests/: 16 testes passaram, cobrindo ausência de token, BOLA, campo extra, cadastro sem privilégio, CORS, headers e limite de autenticação.
- Smoke test com PostgreSQL 16.15: recurso de B retornou 403 para A, 200 para B e 401 sem token; continuou acessível após reinício da API.
- OWASP ZAP 2.17.0 real, análise passiva sem autenticação: 17 URLs importadas; relatório HTML/JSON exportado com execução concluída.

Finding Medium do ZAP

CSP style-src 'unsafe-inline' em /docs: **risco aceito para o TP2 local, não corrigido**. A exceção permite estilos inline na interface Swagger; removê-la sem validar compatibilidade pode quebrar a documentação. Scripts são restringidos à origem própria e a hash específico, e a exceção não vale para as demais respostas. Antes de exposição pública, restringir /docs ou validar uma interface com CSP mais estrita. Não houve finding High.

Limitações e próximos passos

- O Bitext é inglês e híbrido/sintético; frequências e métricas internas não representam automaticamente chamados reais em português.
- O B2W contém avaliações de produto de 2018, não chamados de suporte com intenção original.
- A amostra humana de 500 é estratificada por nota; 78 casos incertos ficam fora da métrica principal. Não deve estimar a distribuição natural do atendimento.
- O ZAP foi passivo e sem autenticação. Não prova ausência de IDOR ou falhas de negócio; testes de ownership são evidência separada.
- /predictions/predict ainda grava resposta placeholder. Integrar e validar o modelo é etapa posterior, não resultado deste TP2.

Entrega e referências

Código, notebooks e relatórios: [repositório na main](#).

Findings detalhados: [relatório OWASP ZAP](#).

Exportação da ferramenta: [relatório ZAP em HTML](#).

EDA estruturada: [relatório TP2 de dados](#).

Fontes dos dados: [B2W-Reviews01 \(CC BY-NC-SA 4.0\)](#); [Bitext Retail eCommerce \(CDLA-Sharing-1.0\)](#).

Este PDF resume a evidência versionada no repositório. Os dados brutos não foram incorporados ao PDF ou ao Git por tamanho e licença; os scripts de download e verificação estão no repositório.